

Acme Technologies - Information Security Policy

Version: 2026.1

Document owner: Security

Effective date: January 1, 2026

Internal enterprise knowledge base document for LoreForge demonstrations.

Table of Contents

1. Purpose and Scope
2. Data Classification
3. Password Requirements
4. Multi-Factor Authentication
5. Access Control
6. Encryption Standards
7. Device Security
8. Incident Reporting
9. Third-Party Access
10. Engineering Security Controls
11. Related Documents

1. Purpose and Scope

This policy defines minimum security requirements for Acme Technologies employees, contractors, systems, repositories, cloud accounts, and internal services. It applies to all company data, customer data, source code, production systems, and business applications.

The policy supports the workplace expectations in the Acme Technologies Employee Handbook and the engineering controls in the Acme Technologies Engineering Handbook.

2. Data Classification

Acme Technologies uses four data classes.

2.1 Public

Information approved for public release, including published marketing pages, public documentation, and open-source notices.

2.2 Internal

Information intended for Acme Technologies personnel and approved contractors. Examples include internal roadmaps, ordinary project notes, and non-sensitive process documentation.

2.3 Confidential

Information that could harm Acme Technologies, customers, employees, or partners if disclosed. Examples include customer configurations, security findings, non-public financial information, employee records, incident notes, and private architecture diagrams.

2.4 Restricted

Highly sensitive information requiring strict access control. Examples include production credentials, signing keys, regulated customer data, privileged audit logs, and vulnerability exploit details.

Confidential and Restricted data must not be copied into unapproved AI tools, personal storage, personal email, or unmanaged devices.

3. Password Requirements

All company passwords must meet these requirements:

- Minimum length: 14 characters.
- Unique per system unless single sign-on is used.

- Generated and stored in an approved password manager.
- Not based on employee names, company names, project names, dates, dictionary phrases, or reused patterns.
- Not shared through chat, email, tickets, documents, screenshots, shell history, or source code.

Password rotation requirements:

- Standard employee credentials rotate every 180 days.
- Privileged, production, and administrator credentials rotate every 90 days.
- Service credentials rotate at least every 90 days unless managed through an automated secret rotation system.
- Immediate rotation is required after suspected compromise, employee transfer, vendor offboarding, or accidental disclosure.

Emergency credentials must be stored in the approved vault with named owner, purpose, expiry date, and access log review.

4. Multi-Factor Authentication

MFA is required for:

- Email and identity accounts.
- Source control.
- Cloud provider consoles.
- Production monitoring and logging tools.
- VPN or zero-trust access tools.
- Administrative SaaS applications.
- Password manager access.

Preferred MFA methods are hardware security keys and authenticator applications. SMS-based MFA is allowed only as a temporary fallback approved by Security.

5. Access Control

Access must follow least privilege. Users receive only the access required for their role and current project.

Access requirements:

- All access must be tied to an individual identity.
- Shared user accounts are prohibited.
- Production access requires manager approval and Security approval.
- Access reviews occur quarterly for production systems and semi-annually for standard business systems.
- Access must be removed within one business day after role change or termination.

Cross-team access to customer data requires documented business justification. The Incident Response Playbook defines emergency access expectations during SEV-1 and SEV-2 incidents.

6. Encryption Standards

Encryption is required for Confidential and Restricted data.

Minimum standards:

- TLS 1.2 or newer for data in transit.
- AES-256 or cloud-provider equivalent encryption for data at rest.
- Managed key services for production storage where available.

- Disk encryption on all company-managed laptops.
- Encrypted backups for production databases.

Keys must not be committed to source control. Key access must be restricted, logged, and reviewed. Production deployment pipelines must not print secrets in logs.

7. Device Security

Company work must be performed on company-managed devices unless Security grants an exception.

Required controls:

- Full-disk encryption.
- Screen lock after 10 minutes or less.
- Endpoint protection.
- Operating system security updates within 14 days of release for standard updates and 72 hours for critical updates.
- Device management enrollment.
- Local administrator rights only when approved for a defined need.

Lost or stolen devices must be reported immediately. Security may remotely lock or wipe managed devices.

8. Incident Reporting

Employees must report suspected security incidents immediately through the designated incident channel or on-call escalation path.

Reportable events include:

- Suspected credential compromise.
- Lost or stolen company device.
- Unauthorized access attempt.
- Customer data exposure.
- Malware or phishing success.
- Production system compromise.
- Security control bypass.

The Incident Response Playbook defines severity levels, escalation ownership, communications, recovery, and postmortem requirements.

9. Third-Party Access

Third-party vendors may access company systems only after Security review, business owner approval, and contract review where required.

Vendor access must:

- Be time-bound.
- Use individual identities.
- Require MFA.
- Be limited to approved systems.
- Be removed when the engagement ends.
- Be reviewed at least quarterly for production or customer-data access.

Vendors must not receive production credentials through email, chat, or documents.

10. Engineering Security Controls

The Engineering Handbook defines Git workflow, pull request expectations, testing, CI/CD, logging, monitoring, and production deployment controls. Security requirements that directly affect engineering include:

- Pull requests must be reviewed before merge.
- Secrets must not be committed.
- Production deploys require CI success and change approval.
- Services must expose health and readiness endpoints when applicable.
- Logs must avoid passwords, tokens, personal data, and customer document contents.

Security exceptions require a documented risk owner, mitigation plan, and expiration date.

11. Related Documents

This policy should be read with:

- Acme Technologies - Employee Handbook.
- Acme Technologies - Engineering Handbook.
- Acme Technologies - Incident Response Playbook.
- Acme Technologies - Cloud Operations Runbook.